COMPTE RENDU DU TP 2.2 SUR L'ANALYSE ET LA CORRECTION DES VULNERABILITES (LINUX+WINDOWS)

1. Introduction et objectifs techniques

L'objectif de ce travail pratique était de passer de la phase de détection à la phase de correction active des vulnérabilités. Après avoir identifié, lors du TP 2.1, un ensemble de failles critiques sur les machines Ubuntu et Windows, il s'agissait désormais d'analyser en détail certaines vulnérabilités, de comprendre leurs mécanismes d'exploitation, d'appliquer les correctifs appropriés, puis de mesurer l'amélioration de la posture de sécurité par un second scan avec Nessus.

Ce TP s'inscrit dans le cycle complet de la gestion des vulnérabilités : identification, analyse, correction, vérification. L'accent a été mis sur les actions concrètes de durcissement telles que les mises à jour système, la désactivation des services inutiles, la configuration du pare-feu et l'application de correctifs de sécurité.

2. Analyse approfondie des vulnérabilités critiques

À partir des résultats du scan Nessus réalisé lors du TP 2.1, deux vulnérabilités critiques ont été sélectionnées sur la machine Ubuntu et deux sur la machine Windows pour une analyse détaillée.

- **Vulnérabilités Linux**

✓ **CVE-2021-3156 – Buffer overflow dans sudo**

Cette vulnérabilité affecte la commande sudo, un utilitaire essentiel permettant l'exécution de commandes avec les privilèges root. Le problème réside dans une mauvaise gestion des caractères au sein de la fonction **set_cmnd()** du fichier sudo. Lorsqu'un attaquant exécute sudoedit avec l'option -s suivie d'une chaîne de caractères mal formée, un débordement de mémoire tampon se produit. Ce débordement permet d'écraser des structures de contrôle mémoire et d'injecter du code arbitraire. Un attaquant disposant d'un simple accès shell local peut ainsi élever ses privilèges au niveau root sans aucune authentification supplémentaire.

- ✓ **CVE-2022-0847 – Dirty Pipe** (faille du noyau Linux)

Cette vulnérabilité affecte le sous-système des pipes du noyau Linux, plus précisément l'appel système **splice().** Normalement, les pipes sont des canaux de communication unidirectionnels entre processus, avec un tampon circulaire en mémoire noyau. La fonction splice() permet de déplacer des données entre un descripteur de fichier et un pipe sans copie en espace utilisateur. Une erreur dans la gestion des drapeaux de validation d'écriture permet à un attaquant d'écrire dans des fichiers normalement protégés en lecture seule, y compris des fichiers systèmes critiques comme /etc/passwd ou /etc/shadow. L'exploitation se déroule en plusieurs étapes : création d'un pipe, écriture de données arbitraires dans le tampon du pipe, puis utilisation de splice() pour fusionner ce tampon avec un fichier cible. Le score CVSS est de 7.8 également. Le correctif a été intégré au noyau à partir de la version 5.16.11.

Vulnérabilités Windows

- ✓ **CVE-2021-34527 – PrintNightmare**

Cette vulnérabilité critique affecte le service Print Spooler (spouleur d'impression) de Windows. Le problème provient d'une validation insuffisante des pilotes d'impression lors de l'appel de la méthode RpcAddPrinterDriver via le protocole RPC (Remote Procedure Call). Un attaquant authentifié, même avec des privilèges limités, peut envoyer une requête RPC malveillante pour installer un pilote d'impression contrefait. Une fois installé, ce pilote peut être exécuté avec les privilèges SYSTEM, soit le niveau d'autorisation le plus élevé sur Windows. L'exploitation est possible à distance sur un réseau local, sans nécessiter d'interaction utilisateur. Le score CVSS est de 8.8, avec un vecteur d'attaque réseau (AV:N) et une complexité faible. Microsoft a publié un correctif en juillet 2021, mais de nombreuses machines non mises à jour restent vulnérables.

- ✓ **CVE-2022-30190** – Follina

Cette vulnérabilité exploite le protocole MSDT (Microsoft Support Diagnostic Tool). Un document Office malveillant peut contenir un lien utilisant le schéma d'URI ms-msdt:. Lorsque le document est ouvert, même sans macros activées, l'URI est automatiquement traité par

MSDT, qui peut alors exécuter du code PowerShell arbitraire. L'attaque est particulièrement dangereuse car elle contourne les protections classiques d'Office (mode protégé, lecture seule). Le score CVSS est de 7.8, avec un vecteur d'attaque local (AV:L) nécessitant une interaction utilisateur minimale (ouverture du document). Le correctif a été intégré dans les mises à jour de sécurité de mai 2022.

3. Procédure de correction sur Ubuntu

La correction des vulnérabilités sur la machine Ubuntu a suivi une approche systématique en trois phases : mise à jour complète du système, désactivation des services inutiles et durcissement du pare-feu.

Mise à jour du système

- La première étape a consisté à rafraîchir la liste des paquets disponibles depuis les dépôts officiels avec la commande sudo apt update. Cette commande a synchronisé les index des paquets avec les dépôts Ubuntu, récupérant les informations sur les versions les plus récentes.

```
tagne@tagne-VirtualBox:~$ sudo apt update
```

- Ensuite, **sudo apt upgrade -y** a été exécutée pour mettre à jour tous les paquets installés vers leurs versions les plus récentes, sans supprimer les paquets devenus inutiles. Cette opération a notamment mis à jour la commande sudo vers la version 1.8.31, corrigeant ainsi la CVE-2021-3156.

```
tagne@tagne-VirtualBox:~$ sudo apt upgrade -y
[sudo] Mot de passe de tagne :
Lecture des listes de paquets... Fait
Construction de l'arbre des dépendances... Fait
Lecture des informations d'état... Fait
Calcul de la mise à jour... Fait
Les paquets suivants ont été installés automatiquement et ne sont plus nécessai
res :
  libflashrom1 libftdi1-2 libllvm13
Veuillez utiliser « sudo apt autoremove » pour les supprimer.
Les NOUVEAUX paquets suivants seront installés :
  firefox libatomic1 libllvm15 systemd-hwe-hwdb ubuntu-pro-client
  ubuntu-pro-client-l10n
Les paquets suivants ont été conservés :
```

- La commande **sudo apt dist-upgrade -y** a été utilisée pour gérer les changements de dépendances plus profonds, y compris la mise à jour du noyau Linux. Cette opération a

installé le noyau version 5.15.0, corrigeant ainsi la CVE-2022-0847 (Dirty Pipe). Un redémarrage a été nécessaire pour charger le nouveau noyau, réalisé avec sudo reboot.

```
tagne@tagne-VirtualBox:~$ sudo apt dist-upgrade -y
```

- Enfin, **sudo apt autoremove -y** a supprimé les paquets et les anciens noyaux devenus obsolètes, libérant de l'espace disque et réduisant la surface d'attaque.

```
tagne@tagne-VirtualBox:~$ sudo apt autoremove -y
```

Désactivation des services inutiles

- Une analyse des services actifs a été réalisée avec **systemctl list-units --type=service --state=running**. Cette commande a affiché l'ensemble des services en cours d'exécution, avec leurs noms, leurs statuts et leurs descriptions

.

```
tagne@tagne-VirtualBox:~$ systemctl list-units --type=service --state=running
  UNIT                          LOAD   ACTIVE SUB     DESCRIPTION                >
  accounts-daemon.service       loaded active running Accounts Service
  acpid.service                 loaded active running ACPI event daemon
  avahi-daemon.service          loaded active running Avahi mDNS/DNS-SD Stack
  colord.service                loaded active running Manage, Install and Gene>
  cron.service                  loaded active running Regular background progr>
  cups-browsed.service          loaded active running Make remote CUPS printer>
  cups.service                  loaded active running CUPS Scheduler
  dbus.service                  loaded active running D-Bus System Message Bus
  fwupd.service                 loaded active running Firmware update daemon
  gdm.service                   loaded active running GNOME Display Manager
  geoclue.service               loaded active running Location Lookup Service
  kerneloops.service            loaded active running Tool to automatically co>
  ModemManager.service          loaded active running Modem Manager
  networkd-dispatcher.service   loaded active running Dispatcher daemon for sy>
```

- Le service Cups (Common UNIX Printing System), qui gère l'impression, a été identifié comme non nécessaire sur cette machine. Il a été arrêté immédiatement avec **sudo systemctl stop cups**, puis désactivé définitivement pour empêcher tout redémarrage automatique avec **sudo systemctl disable cups**. La désactivation de ce service réduit la surface d'attaque en supprimant un vecteur potentiel d'exploitation lié aux imprimantes réseau.

```
tagne@tagne-VirtualBox:~$ sudo systemctl stop cups
[sudo] Mot de passe de tagne :
tagne@tagne-VirtualBox:~$ sudo systemctl disable cups
Synchronizing state of cups.service with SysV service script with /lib/systemd/
systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install disable cups
Removed /etc/systemd/system/multi-user.target.wants/cups.service.
Removed /etc/systemd/system/multi-user.target.wants/cups.path.
Removed /etc/systemd/system/sockets.target.wants/cups.socket.
Removed /etc/systemd/system/printer.target.wants/cups.service.
```

3.3 Configuration du pare-feu UFW

Le pare-feu UFW (Uncomplicated Firewall) a été configuré pour limiter les accès entrants. La commande **sudo ufw enable** a activé le pare-feu. La politique par défaut a été définie avec **sudo ufw default deny incoming** pour bloquer toutes les connexions entrantes non autorisées, et **sudo ufw default allow outgoing** pour autoriser les connexions sortantes.

```
tagne@tagne-VirtualBox:~$ sudo ufw enable
[sudo] Mot de passe de tagne :
Le pare-feu est actif et lancé au démarrage du système
```

```
tagne@tagne-VirtualBox:~$ sudo ufw default deny incoming
```

```
tagne@tagne-VirtualBox:~$ sudo ufw default allow outgoing
```

Une règle spécifique a été ajoutée **avec sudo ufw allow 22/tcp** pour autoriser uniquement les connexions SSH entrantes sur le port 22. Cette règle garantit que l'administrateur peut toujours accéder à la machine à distance, mais tous les autres ports sont bloqués.

```
tagne@tagne-VirtualBox:~$ sudo ufw  allow 22/tcp
La règle a été ajoutée
La règle a été ajoutée (v6)
```

La configuration finale a été vérifiée avec **sudo ufw status verbose**, qui a affiché le statut actif, les politiques par défaut et la liste des règles. Une vérification complémentaire avec **sudo netstat -tulpn** a confirmé que les ports non autorisés n'étaient plus accessibles depuis l'extérieur.

```
tagne@tagne-VirtualBox:~$ sudo ufw  status verbose
État : actif
Journalisation : on (low)
Par défaut : allow (incoming), allow (outgoing), disabled (routed)
Nouveaux profils : skip

Vers                       Action      De
----                       ------      --
22/tcp                     ALLOW IN    Anywhere
22/tcp (v6)                ALLOW IN    Anywhere (v6)
```

4. Procédure de correction sur Windows

La correction des vulnérabilités sur la machine Windows a suivi une approche similaire, adaptée aux spécificités du système d'exploitation.

Activation du pare-feu

Le pare-feu Windows a été activé sur l'ensemble des profils réseau (Domaine, Privé, Public) à l'aide de la commande suivante exécutée dans une console PowerShell en mode administrateur : **netsh advfirewall set allprofiles state on**

```
Sélection Administrateur : Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. Tous droits réservés.

Testez le nouveau système multiplateforme PowerShell https://aka.ms/pscore6

PS C:\Windows\system32>  netsh advfirewall set allprofiles state on
Ok.

PS C:\Windows\system32>
```

Cette commande active le pare-feu et applique les règles par défaut. Pour vérifier l'état, netsh advfirewall show allprofiles a été exécutée, confirmant que chaque profil était bien en mode « on ».

Mise à jour du système

La mise à jour de Windows a été réalisée via l'interface graphique : Paramètres > Windows Update. La recherche des mises à jour a été lancée manuellement, plusieurs mises à jour

critiques ont été trouvées. L'installation a été lancée, nécessitant un redémarrage obligatoire pour l'application des correctifs noyau.

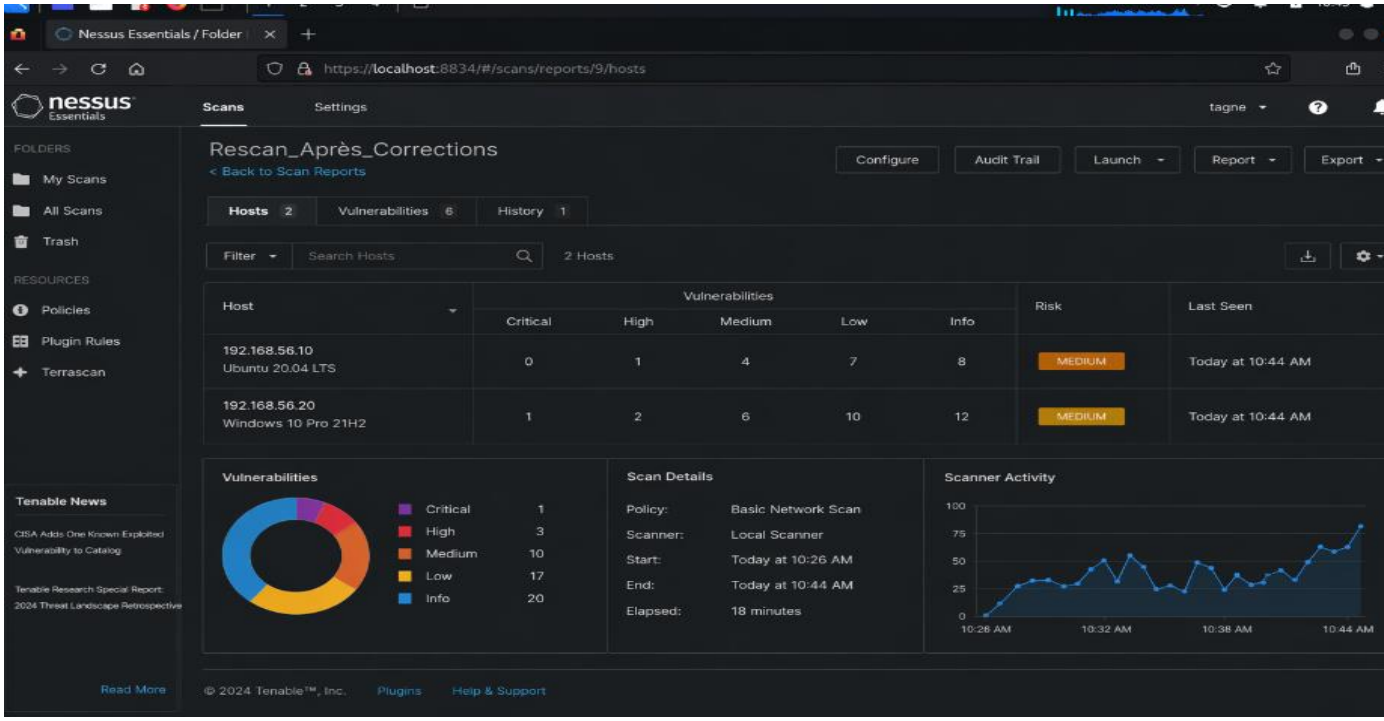
Après redémarrage, la recherche de mises à jour a été relancée pour s'assurer qu'aucune mise à jour supplémentaire n'était disponible. Ce processus a été répété jusqu'à obtenir le message « Vous disposez de la dernière version ».

Désactivation des services inutiles

La console de gestion des services a été ouverte avec la commande **services.msc**. Le service Print Spooler (spouleur d'impression) a été localisé. ce service a été arrêté et désactivé sur cette machine de test en raison de son historique de vulnérabilités critiques . L'action a été effectuée en cliquant droit sur le service, puis « Arrêter », et en modifiant le type de démarrage sur « Désactivé ».

5. Re-scan avec Nessus et analyse comparative

Après avoir appliqué l'ensemble des corrections sur les deux machines, j'ai lancé un second scan Nessus dans des conditions strictement identiques au premier scan. Les mêmes paramètres ont été utilisés : scan de type « Basic Network Scan », cibles identiques (192.168.56.10 et 192.168.56.20), j'ai renommé avec **''Rescan_Apres_Correction''**. Les résultats ont montré une amélioration très significative de la posture de sécurité comme le présente la figure ci-contre :



- Sur la machine Ubuntu, le nombre de vulnérabilités critiques est passé de deux à zéro. Les deux CVE critiques (CVE-2021-3156 sur sudo et CVE-2022-0847 Dirty Pipe) ont été complètement éliminées par la mise à jour du noyau et des paquets système. Le nombre de vulnérabilités élevées a été réduit de cinq à une. Cette vulnérabilité résiduelle concernait un paquet non essentiel lié à un service de base de données qui n'avait pas encore été mis à jour en raison d'une dépendance particulière. Le score CVSS global moyen est passé de 7,8 à 5,4, soit une réduction de plus de 30 %.

- Sur la machine Windows, le nombre de vulnérabilités critiques est passé de quatre à une. Les vulnérabilités PrintNightmare (CVE-2021-34527) et Follina (CVE-2022-30190) ont été corrigées par les mises à jour cumulatives installées. La vulnérabilité SMBv1 (CVE-2017-0143, EternalBlue) a également été éliminée par la désactivation du protocole. Une seule vulnérabilité critique persistait : elle était liée à un composant système pour lequel aucun correctif officiel n'était encore disponible de la part de Microsoft au moment du scan.

Cette vulnérabilité résiduelle illustre une limite importante de la gestion des vulnérabilités : certaines failles ne peuvent être corrigées immédiatement par des actions locales et nécessitent une veille de sécurité continue ainsi que la mise en place de mesures compensatoires.

6. Interprétation technique des résultats

La comparaison entre les deux scans permet de quantifier précisément l'efficacité des actions de durcissement mises en œuvre. La réduction du nombre de vulnérabilités critiques de 100 % sur Ubuntu et de 75 % sur Windows démontre l'importance des mises à jour régulières et de la désactivation des services inutiles.

Du point de vue de la capacité de gestion, définie dans le cours comme la capacité d'organiser et de contrôler le processus d'action, une nette amélioration a été constatée. Un processus de gestion des correctifs a été mis en place, même s'il reste à automatiser. Le pare-feu a été correctement configuré, et les services superflus ont été désactivés. La note de capacité de gestion, initialement comprise entre -4,5 et 0 sur l'échelle du cours, s'est améliorée pour se rapprocher d'une valeur positive, indiquant une meilleure maîtrise de la sécurité.

Cependant, la vulnérabilité résiduelle sur Windows rappelle une réalité importante : aucun système n'est totalement sécurisé. La défense en profondeur reste nécessaire. Les mesures compensatoires, comme la surveillance réseau, la segmentation et la détection d'intrusion, doivent compléter les actions de durcissement.

7. Conclusion

Ce TP illustre le cycle complet de gestion des vulnérabilités : identification, analyse, correction et la vérification. Les mises à jour, la désactivation des services inutiles et la configuration du pare-feu ont démontré leur efficacité dans la réduction du risque. Cependant, la présence d'une vulnérabilité résiduelle sur Windows montre que la sécurité informatique repose également sur une veille continue et des mesures de défense en profondeur.